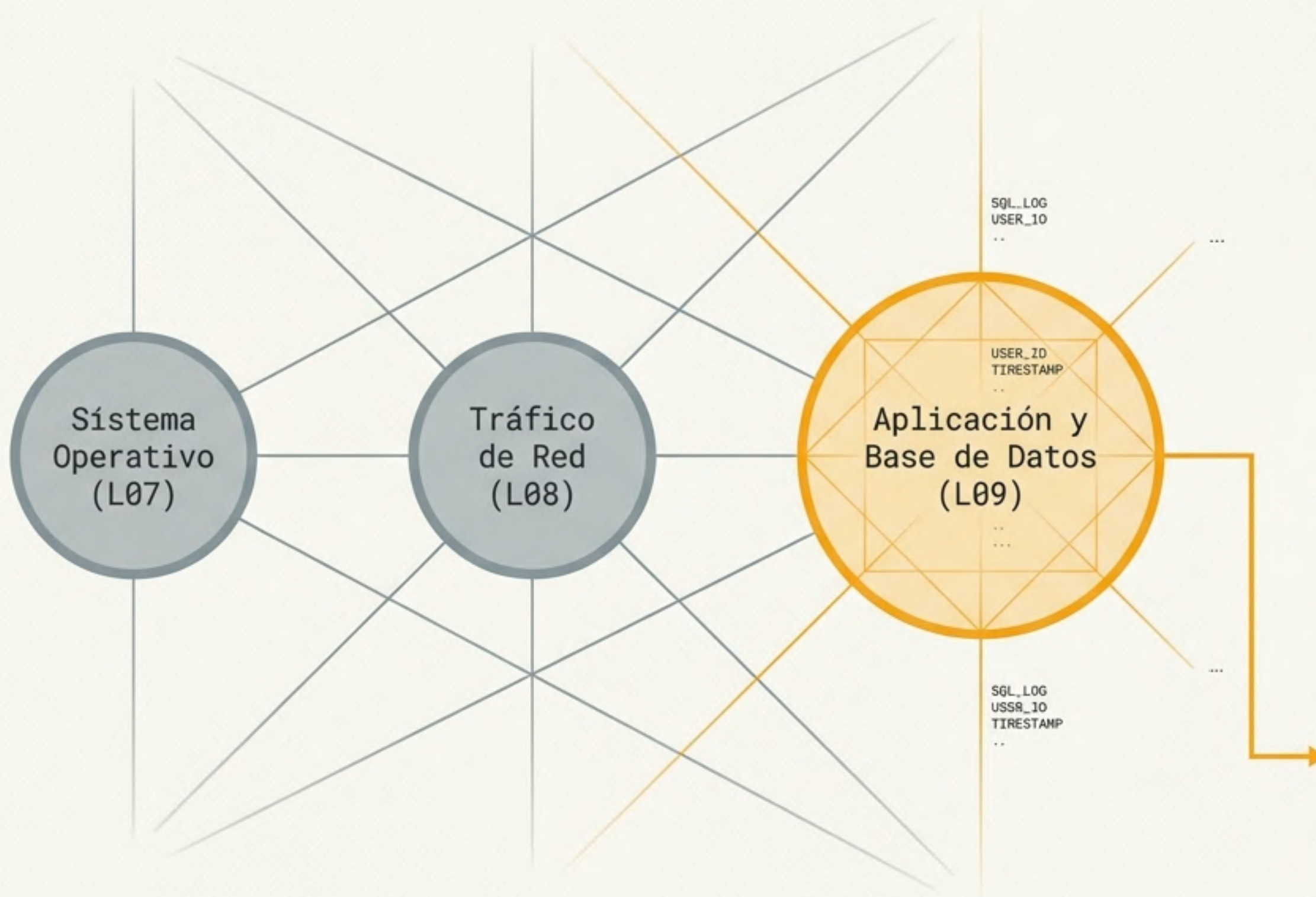


Lección 09: Análisis forense en bases de datos

Registros, transacciones
y correlación de eventos



Lightbox

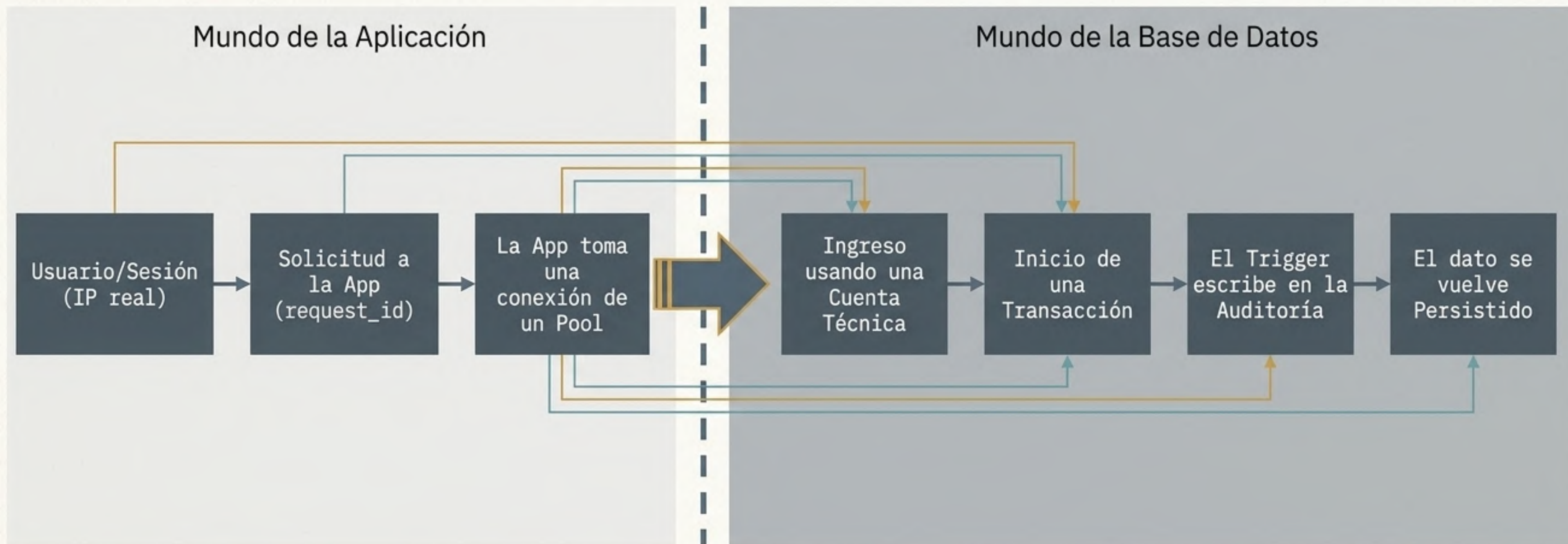
En las lecciones anteriores rastreamos el sistema y los paquetes de red.

Ahora investigaremos el núcleo: qué ocurre dentro de una aplicación, qué sentencias alteraron la base de datos, si el cambio realmente se guardó y a qué cuenta técnica se le atribuye.

Mapa de fuentes de evidencia

	Source	Aporta	Límite
	Registro de la Aplicación	Solicitudes (quién, ruta, resultado <u>HTTP</u>).	Solo anota lo que el programador decidió; suele estar en hora local.
	Registro del Motor (PostgreSQL)	Conexiones, sentencias <u>SQL</u> , <u>errores</u> .	Depende de la configuración; por defecto registra muy poco.
	Tabla de Auditoría	Valores anteriores y nuevos modificados por un <u>trigger</u> .	Confía ciegamente en lo que la aplicación declara.
	Datos Persistidos	El <u>estado de los datos</u> conservado en el momento de la extracción.	Muestra la foto actual, no la historia.
	WAL / RespalDOS	Cambios <u>físicos</u> y fotos antiguas.	Formato interno complejo; se reciclan rápidamente.

El recorrido de una escritura



ALERTA FORENSE: La base de datos ve a la aplicación y a su cuenta técnica, no al usuario final. El usuario registrado en la auditoría es solo una declaración temporal que hace la aplicación.

Vocabulario forense esencial

Tarjetas de Aplicación

request_id

Identificador único de una petición en la app.

1

sesión

Agrupación de solicitudes de un usuario tras loguearse.

2

Tarjetas de Conexión

PID

Número de proceso de la conexión. No identifica a una persona, es un tubo reutilizable.

3

pool

Conjunto de conexiones abiertas que la app recicla.

4

cuenta técnica

Usuario genérico (ej. crm_app) configurado en el sistema.

5

Tarjetas de Base de Datos

xid / txid

Identificador asignado a una transacción cuando modifica datos. Permite correlacionar eventos pertenecientes a una misma transacción.

6

transacción

Grupo de sentencias (todo o nada).

7

trigger

Automatismo de la BD ante un cambio (ej. auditoría).

8

Transacciones: Intento vs. Realidad

El Intento Fallido

```
BEGIN;  
UPDATE...  
ERROR;  
ROLLBACK;
```



Se intentó un cambio.
No quedó guardado. La
fila de auditoría
también se deshace.

El Cambio Confirmado

```
BEGIN;  
UPDATE...  
COMMIT;
```

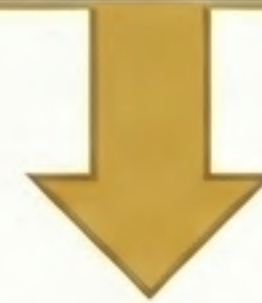
El COMMIT indica que se
ordenó confirmar la
transacción. El resultado debe
corroborarse con la auditoría
y los datos persistidos.



El cambio puede considerarse
confirmado al contrastar la
transacción con la auditoría
y el estado persistido.

Autocommit

```
UPDATE...  
(Sin BEGIN/COMMIT  
explícito)
```



Cada sentencia se
confirma sola. Requiere
buscar si el dato
cambió en la tabla.

Dissección de un registro de PostgreSQL

```
2026-10-01 14:22:12.520 UTC [2210] crm_app@crm app=crm xid=55121 LOG: statement: COMMIT
```

Timestamp (%m). Su zona horaria depende de log_timezone; en este ejemplo está expresado en UTC.

PID: proceso del servidor PostgreSQL que atiende esa conexión. Permite seguir la secuencia de eventos de una conexión, pero no identifica a una persona.

Cuenta técnica y base de datos (%u@%d).

Identificador de la transacción (%x).

La sentencia ejecutada.

¿Por qué a veces veo xid=0? Significa que la transacción todavía no ha recibido un identificador de transacción. PostgreSQL lo asigna cuando la transacción modifica datos por primera vez.

La trampa de la configuración (Logging)

	log_statement	Define qué nivel de sentencias se anotan (none, ddl, mod, all).
	log_line_prefix	Define qué datos encabezan la línea (%m hora, %p PID, %x xid).
	log_timezone	Zona horaria del archivo de log. Crucial para correlacionar con la aplicación.
	log_min_duration_statement	Registra sentencias solo si superan ciertos milisegundos (-1 lo desactiva).

PRINCIPIO FORENSE CENTRAL: Una ausencia en el registro del motor solo significa que 'no ocurrió' si el motor estaba configurado para registrarlo. Revisar estos parámetros es el paso cero de la investigación.

Auditoría automatizada con Triggers

1. Declaración

La app inyecta variables temporales antes del cambio.

```
SET LOCAL app.usuario = 'tvera';
```

2. Modificación

Se ejecuta un `UPDATE` sobre el dato.

3. Captura (Trigger)

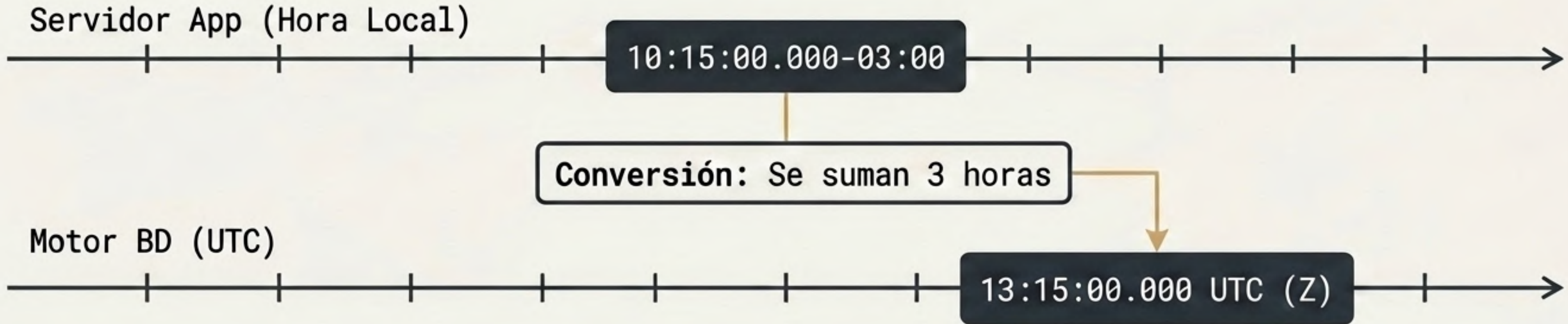
El trigger interno captura los valores `OLD` (anterior) y `NEW` (nuevo), el identificador `txid` y la variable temporal (`tvera`).

REGLA DE ORO FORENSE

La fila de auditoría forma parte de la misma transacción que el cambio.

Si ocurre `ROLLBACK`, también se revierte. Si ocurre `COMMIT`, la fila puede quedar persistida.

El tiempo forense: Normalización y desviación



Precaución con funciones SQL

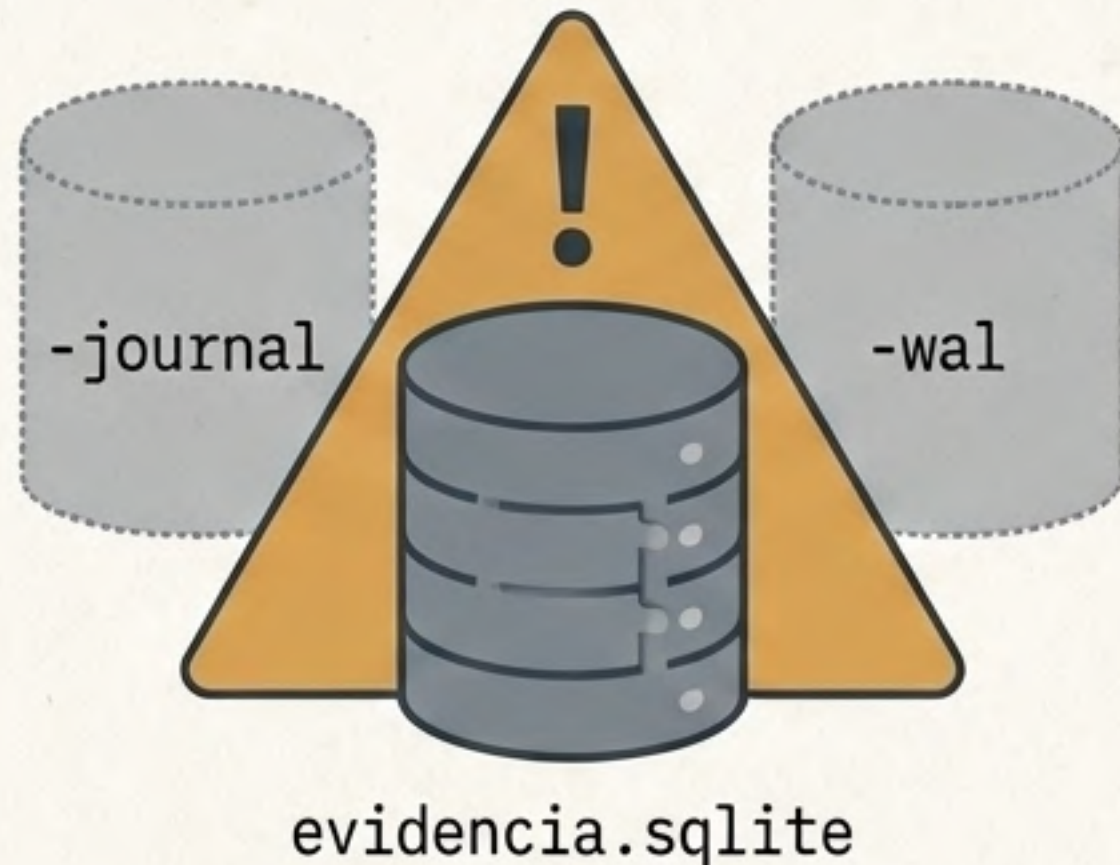
- **transaction_timestamp():** Hora de inicio de la transacción entera (común en auditorías).
- **statement_timestamp():** Hora de inicio de la sentencia específica.
- **clock_timestamp():** Hora real del reloj del sistema.

Alerta: Desviación de reloj (Drift)

Los servidores pueden tener pequeñas desviaciones de reloj. Una diferencia de pocos milisegundos no establece por sí sola el orden de los eventos.

Prioriza identificadores compartidos y secuencia lógica sobre diferencias temporales pequeñas.

Preservación específica de bases de datos



EL RIESGO: Una base de datos es evidencia frágil. Abrirla normalmente puede modificar sus cabeceras y crear archivos auxiliares automáticos, alterando su estado original.

La Solución Forense



Trabajar siempre sobre una copia (verificar Hash antes y después).



Comando vital:

```
sqlite3 -readonly  
'file:evidencia.sqlite?immutable=1'
```

- **-readonly:** abre la base impidiendo operaciones de escritura desde SQLite.
- **immutable=1:** declara que el archivo no debe cambiar y evita el comportamiento normal de creación de archivos auxiliares junto a la evidencia.



Ejecutar solo sentencias **SELECT**.



Documentar tus propias consultas para no confundirlas con el incidente original.

Lectura práctica: Comandos y Citación

Comandos Útiles

`.tables` → Lista las tablas existentes.

`.schema tabla` → Muestra columnas y tipos de datos.

`SELECT * FROM auditoria
WHERE id = 8;` → Filtra filas específicas.

`grep -n 'R-100' app.log` → Busca texto y extrae el número de línea exacto.

Cómo Citar la Evidencia

En el análisis forense no se memoriza, se cita de manera trazable.

Para Logs

"Archivo X, línea N"

Para BD

"Tabla Y, fila id = N"

Matriz de correlación multifuente

	Directa (Confianza Alta) Dato: Se comparte un identificador único. Ejemplo: Mismo request_id entre App y Auditoría; mismo xid/txid entre Log y Auditoría.
	Por Valor (Confianza dependiente del contexto) La fuerza de la relación depende de cuán específico o repetible sea el valor y de las demás evidencias que lo respalden. Dato: Se comparte un dato repetible. Ejemplo: Misma IP, cuenta técnica o ID de cliente. Puede coincidir por coincidencia u otras razones.
	Solo Temporal (Confianza Baja) Dato: Eventos cercanos en tiempo. Ejemplo: 'Ocurrieron en el mismo milisegundo'. Sirve para encontrar pistas, no para concluir causalidad.

Método de Análisis (Caso Práctico Hipotético)

Ejemplo: Intento de aumento de sueldo.

Paso 1: Localizar Solicitud (Log de App)

`request_id='req-99' →
intenta cambio → Falla
(HTTP 500)`

`request_id='req-100' →
intenta cambio → Éxito
(HTTP 200)`

Paso 2: Seguir Transacción (Log PostgreSQL UTC)

`request_id='req-99' →
Causa error →
'ROLLBACK'`

`request_id='req-100' →
xid=8842 → 'COMMIT'`

Paso 3: Contrastar Auditoría (Tabla)

`Fila con "txid=8842" →
Sueldo anterior: 1000,
Nuevo: 1500`

Paso 4: Dato Persistido (Tabla actual)

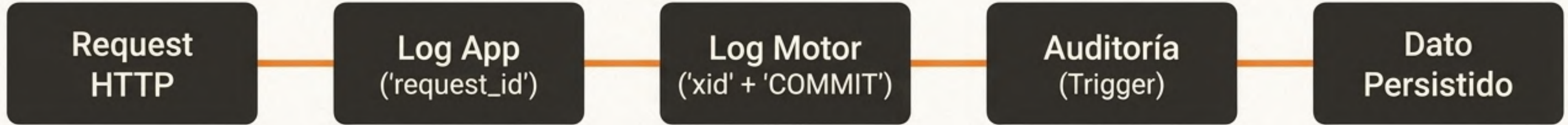
`Select actual → Sueldo
= 1500`

Conclusión del Flujo: Identificar, Seguir, Confirmar y Contrastar.

Errores frecuentes (Mito vs. Realidad)

 Mito	 Realidad
<code>`HTTP 200`</code> = Cambio confirmado	La app declara éxito; el cambio exige ver un <code>`COMMIT`</code> y el dato persistido.
<code>`HTTP 500`</code> = Nada cambió	Un HTTP 500 solo indica que la solicitud terminó con error. Revisa el motor, la transacción, la auditoría y los datos persistidos de antes de concluir si hubo cambios.
El <code>`PID 2210`</code> es el usuario	Es el PID de un proceso de PostgreSQL asociado a una conexión. Una conexión proveniente del pool puede reutilizarse para solicitudes de distintos usuarios.
Misma hora = mismo evento	Los relojes se desvían; siempre busca identificadores directos (<code>`xid`</code> , <code>`req_id`</code>).
Sin log = no ocurrió	Pudo no estar configurado. Comprueba primero los parámetros de logging.

Síntesis y formulación de conclusiones



Afirma solo lo respaldado

- Incorrecto: Tamara cambió el dato.
- Correcto: La solicitud `Q-881` de la sesión de la cuenta 'tvera' cambió el dato y quedó persistido.

Declara qué falta

- Los registros de Base de Datos prueban el comportamiento lógico del sistema, pero no prueban quién estaba frente al teclado.
- Para atribuir la acción a una persona se requieren fuentes adicionales, como registros del sistema operativo, VPN, directorio corporativo, autenticación multifactor u otras fuentes independientes.